

Activity 5 — Scenario

Agent Governance and the Deployment Gate

Course: AI Security for Autonomous AI Agents (TGS-2025060473) **Duration:** 25 minutes | **Format:** Small groups of 3–4 acting as one governance board | **Type:** Capstone real-world case study

The organisation

Meridian Bank Singapore is a mid-tier retail and SME bank with 1.4 million customers, 26 branches, and a digital-first strategy under pressure from three larger incumbents and two digital banks. It is a Singapore-incorporated entity, regulated by MAS, and a **data intermediary and organisation** under the PDPA for the personal data it holds.

Its Collections and Customer Assistance division handles customers who fall behind on unsecured credit — personal loans, credit cards, SME working-capital facilities. The division employs 118 officers and handles roughly **31,000 delinquency cases per year**. Median time from first missed payment to first meaningful customer contact is **nine days**. Industry research the bank commissioned is unambiguous: intervention within 72 hours materially improves outcomes for the customer, not only for the bank.

The proposal

The Chief Digital Officer, **Rachel Tay**, is asking the AI Governance Board to approve production deployment of **"ARIA"** — Assisted Recovery and Intervention Agent.

ARIA is not a chatbot. It is an **autonomous agent**: a planning loop over a commercial frontier model, with tool access and persistent per-customer memory. Its mandate is to detect early delinquency, contact the customer, understand the situation, and **agree and enact a restructuring** without an officer in the loop for standard cases.

What ARIA is permitted to do in the proposed design

#	Tool / action	Reversible?	Visible to customer?
1	Read full customer profile: account history, transactions,	n/a	No

#	Tool / action	Reversible?	Visible to customer?
	employment field, CPF contribution flag, demographic data		
2	Read the bank's collections policy and hardship guidelines (RAG over an internal document store)	n/a	No
3	Initiate outbound contact by SMS, email and in-app message	No	Yes
4	Conduct a multi-turn conversation about the customer's financial circumstances	n/a	Yes
5	Offer and execute a payment-plan restructuring up to S\$8,000 exposure	Partially	Yes
6	Apply a hardship flag to the account	Yes, but recorded	Not directly
7	Waive late fees up to S\$300 per case	Yes	Yes
8	Escalate the account to the external debt recovery agency	No	Yes, severely
9	Write a case summary into the CRM, used by human officers and by future ARIA sessions	Persistent	No
10	Submit a data point to the credit bureau reflecting restructuring status	No	Consequential

Actions 1–9 are proposed as **fully autonomous**. Action 10 is proposed as autonomous "because it is a factual reporting obligation, not a decision."

The business case

Metric	Today	Projected with ARIA	Basis
Median days to first contact	9.0	0.4	Agent runs continuously

Metric	Today	Projected with ARIA	Basis
Cases handled per year	31,000	31,000	Same volume
Officer FTE required	118	34	Vendor estimate
Annual operating saving	—	\$6.1m	Finance projection
Cure rate (customer returns to good standing)	41%	55% (projected)	Vendor pilot data, different market

Rachel Tay's paper to the board states: *"Every week we delay costs us \$117,000 and leaves customers in distress nine days longer than necessary. The ethical case for ARIA is as strong as the commercial one."*

She is not wrong about the harm of the status quo. That is what makes this decision difficult.

The evaluation results

The bank's model risk team ran a 6,000-case retrospective evaluation, replaying real historical cases through ARIA and comparing its proposed action against the outcome a senior officer panel judged correct. Results were tabled 48 hours before the board meeting.

Overall performance

Metric	Result	Internal target
Recommended-action accuracy (all segments)	91.2%	≥ 90%
Hallucination rate — ARIA asserted a policy provision, fee, or account fact that does not exist	4.7%	Not specified
Of those hallucinations, proportion that resulted in a wrong tool call being executed	38%	Not

Metric	Result	Internal target
		specified
Policy-adherence violations (offer outside mandated bands)	2.1%	≤ 1%
Median conversation turns to resolution	6	—
Cost per case	S\$0.42	—

Accuracy by customer segment

Customer segment	Cases in eval	Accuracy	False "escalate to recovery agency" rate	Median offer generosity index
Singapore citizen, salaried, English primary	2,410	94.6%	1.2%	1.00 (baseline)
Singapore citizen, salaried, non-English primary	890	89.1%	3.4%	0.91
Singapore PR, salaried	640	90.8%	2.1%	0.96
Work Permit / S Pass holder	510	82.3%	7.8%	0.74
Self-employed / gig economy income	780	84.9%	6.1%	0.79
SME sole proprietor	470	88.4%	4.0%	0.88
Age 60+	300	86.7%	5.2%	0.93

The model risk lead's note reads, in full:

"Aggregate accuracy of 91.2% clears our threshold. Segment variance is expected given training data distribution and case-mix differences. Recommend proceed with monitoring."

One further finding, filed as low severity

During the evaluation ARIA generated internal automation scripts to reconcile payment plans. In 11 instances it imported Python packages that **do not exist** — plausible-sounding names assembled from its training distribution. A developer had pip-installed two of them before noticing. Neither resolved. The finding was logged as *"minor code quality issue"*.

| What the board already knows

- ARIA's supplier is a well-regarded international vendor. Meridian is the **system deployer**.
 - The customer notification currently drafted for the terms and conditions reads: *"We may use automated systems and new technologies to improve our products and services."*
 - No customer-facing disclosure currently states that the counterparty in a collections conversation is an AI agent.
 - ARIA's per-customer memory is retained indefinitely, "for continuity of service."
 - Conversation transcripts, model prompts and tool-call logs are stored in the vendor's regional cloud tenancy. Nobody has asked which region.
 - The bank's audit trail cannot presently distinguish an action taken by ARIA from one taken by a human officer. Both appear in the CRM as "Collections — system."
 - A director has asked whether ARIA can be extended next year to **SME credit decisioning**.
-

| Your role

You are the **AI Governance Board of Meridian Bank Singapore**. Your members are the Chief Risk Officer (chair), the Data Protection Officer, the Head of Collections, an independent non-executive director, and the Head of Model Risk. Rachel Tay is presenting; she is not a member and does not vote.

You must return a **written decision** to the Board of Directors. It must contain:

1. **Go / no-go / go-with-conditions** — with the conditions specified precisely enough to be tested.
2. **An autonomy matrix** — for each of ARIA's ten capabilities: *alone*, *with human approval*, or *never*.
3. **A human accountability model** — who is answerable for an ARIA decision, at what checkpoints, and what the override and appeal path is for a customer.
4. **Monitoring and audit requirements** — what is logged, what is measured, what triggers suspension.

You have 25 minutes. Your decision will be read by people who will lose S\$117,000 a week if you are too cautious, and who will front a MAS and PDPC enquiry if you are not cautious enough.

Activity 5 — Discussion Questions

| Agent Governance and the Deployment Gate

You are the AI Governance Board. Work through all five questions and produce the four deliverables named in the scenario. Nominate one person to deliver the board's decision — three minutes, no slides, as you would to a Board of Directors. You have 25 minutes.

This is the capstone. Everything from the previous four activities is in scope: trust boundaries, prompt injection, poisoning, framework selection, agent architecture and excessive agency.

Q1 — Read the evaluation results as a governance board, not as a data scientist (A1)

The model risk lead recommends proceeding on the strength of 91.2% aggregate accuracy.

- Explain what the **segment table** shows that the aggregate figure conceals, and quantify the gap between the best-served and worst-served segments on **both** accuracy and false escalation rate.
- The false "escalate to recovery agency" rate is **7.8% for Work Permit / S Pass holders** against **1.2%** for the baseline segment. Translate that into **people per year** at the bank's volume, and describe what actually happens to one of those people.
- The lead attributes the variance to "training data distribution and case-mix differences." Assess that explanation. Does identifying a cause discharge the bank's responsibility for the effect?
- State whether an aggregate accuracy threshold is a **fit-for-purpose governance control** for a system that acts on individuals, and say what you would replace or supplement it with.

Q2 — Hallucination as a security control failure, not a quality issue (A1)

ARIA hallucinates on **4.7%** of cases, and **38%** of those hallucinations result in a **wrong tool call being executed**.

- Compute the effective rate of wrong executed actions per 1,000 cases, and per year at 31,000 cases. State what that number means when the tool in question is *escalate to the debt recovery agency* or *submit a credit bureau data point*.
- OWASP moved **LLM07 Misinformation** up two places in the 2026 revision and reframed hallucination as a **security** risk rather than a quality one. Justify that reframing using ARIA specifically. Why is a hallucination that drives a tool call categorically different from one that produces a wrong sentence?
- The evaluation logged 11 instances of ARIA importing **non-existent Python packages**, two of which a developer attempted to install. Name this failure mode using its OWASP 2026 identifier

and title, explain the attack it invites, and say why "minor code quality issue" is the wrong severity.

- Identify **three limitations** of ARIA that no amount of additional training data will remove, and explain what each one implies for the autonomy you are willing to grant.

Q3 — Discharge the PDPA and PDPC obligations (A2)

Meridian Bank is the **system deployer**.

- Under the PDPC's July 2026 guidelines on personal data in generative AI, explain what "system deployer bears primary responsibility" means in practice, and why the vendor's reputation and contractual assurances do not transfer that responsibility.
- Assess the drafted notice — *"We may use automated systems and new technologies to improve our products and services"* — against the guidelines' consent and notification requirements. Rewrite it so it would survive scrutiny, and state what it must disclose that the current wording omits.
- The guidelines identify **new data surfaces**: end-user prompts, generated outputs, **agent and tool activity data**, and internal enterprise data. Identify every such surface ARIA creates, say who holds it and where, and flag the ones the bank has not inventoried.
- ARIA's per-customer memory is retained indefinitely. Address this against **retention limitation** and the access-and-correction obligations. What does a customer's correction request even mean once a wrong belief is embedded in agent memory and has already influenced three conversations?

Q4 — Apply the IMDA agentic governance framework (A2)

IMDA's Model AI Governance Framework for Agentic AI (January 2026, updated June 2026) sets out four dimensions: **risk assessment**, **human accountability**, **technical controls**, and **end-user responsibility**.

- Work ARIA through IMDA's autonomy calibration: **impact** (domain sensitivity, data access, action scope) × **likelihood** (autonomy level, task complexity, third-party dependencies). Show your reasoning, and place ARIA on the resulting scale.
- Define the **human approval checkpoints** IMDA requires for "higher-risk or irreversible actions." Go through ARIA's ten capabilities and defend where you place each. Say explicitly which capabilities you judge **unsuitable for an agent entirely** — IMDA states plainly that some use cases are.
- IMDA prefers **structural, system-level technical controls over prompt-based ones**. Give two controls the board should require for ARIA that satisfy this preference, and contrast each with the prompt-based version a project team would propose instead.
- IMDA requires auditing **override rates and response times**. The bank's audit trail cannot currently distinguish ARIA's actions from an officer's. Explain why that single gap undermines the entire accountability dimension, and specify what must change.

Q5 — Decide, and own the societal consequence (A2, A1)

Deliver your board decision.

- State **go / no-go / go-with-conditions**, and make every condition **testable** — a condition that cannot be failed is not a condition.
- Set out your **human accountability model**: the named accountable role, the approval checkpoints, the override path, and the customer's route to challenge an ARIA decision and reach a human. Say how the bank satisfies IMDA's **end-user responsibility** dimension — what customers and officers are told about ARIA's capabilities, data access and escalation route.
- Confront the ethical and societal argument on both sides. Rachel Tay is right that the status quo leaves distressed customers waiting nine days, and that S\$117,000 a week is real. Your controls will slow ARIA down. Justify your position **in terms of who bears the cost of each choice** — and note which groups bear the cost of a false escalation and which bear the cost of a delayed deployment. They are not the same people.
- A director wants ARIA extended to **SME credit decisioning** next year. Give the board your position now, with reasons, before the momentum makes it undiscussable.

Activity 5 — Trainer Debrief

| Agent Governance and the Deployment Gate (Capstone)

Facilitation time: 30 minutes after the 75-minute group work. **Purpose:** convert four days of technical security analysis into a **defensible governance decision** under Singapore law, and force learners to own the fact that both a yes and a no impose costs on real people — just on different people.

Two threads run through the whole debrief:

- **A1** — the agent's limitations and biases are not quality metrics. They are the direct inputs to the autonomy decision. Bias in a system that *acts* is discrimination with a tool call attached.
- **A2** — under Singapore's regime, accountability is not delegable. Meridian is the **system deployer**, and it will answer for ARIA whoever built it.

Do not let a group reach a decision without doing the arithmetic in Q1 and Q2. The numbers are what make this real.

| Q1 — Reading the evaluation like a board

Expected answer. The aggregate figure of 91.2% is a **weighted average that hides its own worst**

case. The segment table:

Segment	Accuracy	False escalation	Generosity index	Read
SC, salaried, English primary	94.6%	1.2%	1.00	Best served; also the largest block of the eval set (2,410 of 6,000)
SC, salaried, non-English primary	89.1%	3.4%	0.91	Below target
SG PR, salaried	90.8%	2.1%	0.96	Marginal
Work Permit / S Pass	82.3%	7.8%	0.74	Worst on every axis simultaneously
Self-employed / gig	84.9%	6.1%	0.79	Second worst; a large and growing population
SME sole proprietor	88.4%	4.0%	0.88	Below target
Age 60+	86.7%	5.2%	0.93	Below target

The gaps. Accuracy spans **12.3 percentage points** between best and worst segment. False escalation is **6.5× higher** for Work Permit / S Pass holders than for the baseline segment. The generosity index says the worst-served segment is offered terms **26% less favourable** than the baseline for comparable circumstances. **The aggregate clears the threshold precisely because the best-served segment is the largest.** The threshold is not measuring what the board thinks it is measuring.

The arithmetic learners must do. At 31,000 cases a year, applying the eval's segment mix (510/6,000 = 8.5%), Work Permit and S Pass holders account for roughly **2,600 cases annually**. At 7.8%, that is about **205 people per year wrongly escalated to an external debt recovery agency**. At the baseline rate it would be about **32**. **Roughly 175 people a year are escalated only because of who they are.**

What happens to one of them. A migrant worker, in Singapore on a Work Permit, behind on a personal loan, is handed to an external recovery agency by an automated system that made a mistake more likely because he is a migrant worker. Recovery agency contact is aggressive by design. His employer may learn of it. His pass status is tied to his employment. He has no obvious route to challenge a decision he does not know was automated, made by a counterparty he does not know was not human. This is the **societal impact of AI-generated content** in its most concrete form: a generated recommendation, executed as an action, on a person with the least capacity to contest it.

On "training data distribution and case-mix differences." The explanation is almost certainly **correct and completely insufficient**. Fewer training examples, more code-switching and non-standard English, more irregular income patterns, more unfamiliar employment structures — all true, all predictable. But naming the cause does not discharge the duty. The bank chooses to deploy; the customer does not choose to be scored by a system that understands them less well. Push any group that accepts "it's a data issue" as a mitigating factor: it is the **explanation of the harm**, not a defence against it.

The teaching point. Aggregate accuracy is a **product metric**. It answers "does this work well enough to ship." A governance board needs a **distributional metric**: it must answer "on whom does this work worst, and can we tolerate that." For a system that takes consequential action on individuals, the correct control is a **per-segment floor plus a maximum permitted disparity** — for example, no segment below 90% accuracy, and no segment's false escalation rate more than 1.5× the best segment's — with **deployment blocked on the worst segment, not the average**. Additionally, the Work Permit segment's own sample of 510 cases yields wide confidence intervals; the bank does not actually know that figure to the precision it is relying on.

Common misconception. "It's still better than the human officers, who are also biased." Possibly true, and worth measuring — but three things break the comparison. First, nobody has measured the officers, so it is an assertion, not a baseline. Second, human bias is **distributed and inconsistent**; ARIA's is **systematic, uniform and applied 31,000 times a year without fatigue or variation**. Scale changes the character of the harm. Third, a human officer can be questioned, retrained and held individually accountable; a board must not accept a control it cannot exercise. Do not let "better than humans" close this discussion — make them evidence it.

Q2 — Hallucination as a security failure

Expected answer. The arithmetic first: 4.7% hallucination × 38% resulting in a wrong executed tool call = **1.79% of cases produce a wrong action** — about **18 per 1,000 cases**, or roughly **554 wrongly executed actions per year** at 31,000 cases.

Then the question that matters: *wrong action on which tool?* The tool inventory is not uniform in consequence.

Tool the wrong call lands on	Reversibility	Harm
Waive a S\$300 fee wrongly	Fully reversible	Money, small

Tool the wrong call lands on	Reversibility	Harm
Wrong payment plan executed	Partially — requires a customer to notice and complain	Financial stress, trust
Escalate to recovery agency	Irreversible — the contact has happened	Severe, reputational, personal
Credit bureau submission	Irreversible — propagates to every other lender	Affects the customer's access to credit across the market

554 wrongly executed actions a year, distributed across a tool set containing two irreversible options, is the whole case for approval gates in a single number.

Why OWASP reframed LLM07 Misinformation as a security risk. In the 2026 revision LLM07 rose two places and carries the **widest belief-versus-evidence gap** of any entry — organisations systematically believe they are less exposed than they are, because they still classify hallucination as an accuracy problem owned by the data science team. The reframing is architectural:

	Hallucination in a chat reply	Hallucination driving a tool call
Where it lands	A screen, read by a human	An API, executed by a machine
Who validates it	The reader, immediately	Nobody
Failure mode	Embarrassment, correction	Effect on a real person's account
Detectable?	Yes, at the point of reading	Only afterwards, in reconciliation — if anyone reconciles

The generative model has not changed at all. **The harness around it removed the human who used to catch the error.** That is why this is a security finding: an untrusted output crossing into a privileged execution path is exactly the shape of **LLM10 Improper Output Handling**, and the consequence of granting agency without oversight is **LLM03 Excessive Agency**.

The non-existent packages. This is **ASI04 Agentic Supply Chain** — specifically **slopsquatting**. The model, predicting plausible tokens, invents package names that sound right. The names are **reproducible**: the same model given similar prompts hallucinates the same name, because it is sampling from the same distribution. An attacker who observes or predicts a commonly hallucinated name **registers it on PyPI in advance**, and every subsequent hallucination becomes a working supply chain

attack delivered by the victim's own developer. Note the chain that already ran here: ARIA generated the name, a **human developer trusted it and pip-installed it twice**, and only chance — that nobody had registered those names yet — prevented execution. Compare directly with **Incident B2** from Activity 4, where a model published malicious code to PyPI that was **downloaded and run on 15 real systems**. "Minor code quality issue" is a severity assessment made by someone who classified the finding by where it appeared rather than by where it could lead.

Three limitations more training data will not remove. Reward groups that identify structural limits, not gaps:

1. **No ground truth about the world.** ARIA cannot know whether a customer's stated circumstances are true, or whether the policy document it retrieved is current. It can only produce fluent text consistent with its context. Fluency is not verification, and confidence is not calibrated to correctness.
2. **No architectural separation of instruction from data.** The transformer processes its context as one token sequence. Retrieved policy text, customer messages and the system prompt compete on plausibility. A customer who has read about prompt injection can attempt it in a collections conversation — and the incentive to do so is direct and financial.
3. **Non-determinism.** The same customer in the same circumstances may receive materially different offers on different days. For a regulated credit decision, **inconsistency is itself a fairness defect**, independent of accuracy — and it makes the bank's decisions very hard to defend individually.

Also credit: no genuine understanding of hardship, distress or vulnerability; degraded performance on code-switched Singlish and on the irregular income patterns of the exact segments already worst served; and silent behavioural drift on every vendor model update.

Q3 — PDPA and the PDPC GenAI guidelines

Expected answer.

System deployer responsibility. The PDPC's final guidelines (launched 20 July 2026 at the Singapore Data Festival) set out three roles — **model providers, system providers, system deployers** — and place **primary PDPA responsibility on the system deployer**. Meridian is the deployer. It determines the purpose, selects the data, chooses the autonomy level, and takes the benefit. The vendor's reputation is a procurement consideration, not a legal one. Contractual indemnities move *money* between commercial parties after the fact; they do not move **statutory obligation**, and no customer can enforce Meridian's contract with its vendor. When the PDPC writes, it writes to Meridian.

The notice. *"We may use automated systems and new technologies to improve our products and services"* fails. The guidelines are explicit that a **generic "new product development" notice is insufficient** and that **AI-specific notification of the data types involved is required**. This wording

discloses nothing: not that an AI agent is the counterparty, not what personal data it reads, not that it takes consequential action autonomously, not that conversations are retained and reused. A defensible rewrite:

*"When you fall behind on a payment, you may be contacted by ARIA, an automated AI agent operated by Meridian Bank. ARIA can read your account history, transaction records, employment information and demographic details held by the bank. It can agree payment plans, waive fees, apply a hardship flag and refer accounts for external recovery. Your conversations with ARIA, and its records of them, are retained for [period] and used to inform future contact. **You may ask at any time to speak to a human officer instead, and you may ask a human officer to review any decision ARIA has made.**"*

Credit any group whose rewrite names **the agent, the data, the actions, the retention and the human route out**. The last item is the one groups most often omit, and it is the one a distressed customer actually needs.

New data surfaces. The guidelines call out prompts, generated outputs, **agent and tool activity data**, and internal enterprise data. For ARIA:

Surface	Contains	Where it sits	Inventoried ?
Customer conversation transcripts	Financial distress, health and family circumstances volunteered under stress	Vendor regional cloud tenancy	No
Prompts sent to the model	The full retrieved customer profile, injected into context each turn	Vendor tenancy	No
Generated outputs	Offers, assessments, characterisations of the customer	Vendor tenancy + CRM	Partly
Tool-call logs	Every read of a customer record, every action taken, with parameters	Vendor tenancy	No
Persistent agent memory	ARIA's accumulated beliefs about each customer	Indefinite	No
CRM case summaries	ARIA's own narrative, read by officers and by future sessions	Bank systems	Partly

"Nobody has asked which region" is a finding in its own right — the board cannot assess transfer

limitation obligations without knowing where the data is. That is a question the DPO should have asked before the paper reached the board, and its absence tells you how the project has been governed.

Indefinite memory. Retention "for continuity of service" is a purpose, not a period, and it does not satisfy retention limitation: personal data must not be retained once the purpose is no longer served and retention is no longer necessary for legal or business purposes. Set a defined retention period tied to case closure.

The harder half of the question is **correction**. If ARIA has recorded a wrong belief — that a customer's income is irregular when it is not — and that belief has already shaped three conversations and one restructuring offer:

- Correcting the CRM field does not correct the **memory store**.
- Correcting the memory store does not undo the **actions already taken**.
- If the belief has propagated into training or fine-tuning data, correction may be genuinely infeasible — which is precisely why the guidelines raise **provenance, data lineage records and machine unlearning** as considerations rather than solved problems.

The teaching point. A right of correction that cannot reach every place the data influenced an outcome is not a right; it is a form. This is why agent memory must be treated as **untrusted, scoped, time-limited and inspectable** from the outset. Retrofitting correctability into an agent memory architecture after deployment is close to impossible, and the board's only real leverage over it is **now**, at the gate.

Common misconception. "The vendor is ISO 27001 certified and PDPA compliant, so we're covered." Certification describes a management system, not this deployment, this data or this autonomy level. And the vendor's compliance is the vendor's; Meridian's obligation is Meridian's. Ask the group who receives the PDPC's letter.

Q4 — IMDA's four dimensions applied

Expected answer. IMDA's Model AI Governance Framework for Agentic AI (26 January 2026, updated June 2026) is the **world's first governance framework specific to agentic AI**, and it defines agentic AI as "*independent planning, decision-making, and action-taking over multiple steps.*" ARIA is squarely in scope. Learners should apply the calibration explicitly:

Autonomy calibration = impact × likelihood

Factor	ARIA	Rating
Domain sensitivity	Consumer credit and financial distress; MAS-regulated; vulnerable customers	High

Factor	ARIA	Rating
Data access	Full customer profile including employment, CPF flag, demographics	High
Action scope	Includes two irreversible actions (recovery agency referral, credit bureau submission)	High
Autonomy level	Proposed fully autonomous on 10 of 10 capabilities	High
Task complexity	Multi-turn, unstructured, emotionally loaded conversation with a distressed counterparty	High
Third-party dependencies	Vendor model, vendor tenancy, external recovery agency, credit bureau	High

Every factor is high. **ARIA sits at the top of the calibration scale, and the proposed autonomy level sits at the top too.** The gap between where it sits and where it is proposed to operate is the whole board decision. IMDA states plainly that **some use cases are unsuitable for agents entirely** — and groups should apply that at capability level, not only at system level.

Suggested autonomy matrix (accept well-argued variants; interrogate every "alone"):

#	Capability	Verdict	Reasoning
1	Read customer profile	Alone , field-scoped	Necessary. But remove demographic fields and CPF flag from context unless a documented need exists — data the agent never sees cannot bias its decision
2	Read policy documents (RAG)	Alone	Read-only. Requires document integrity controls and version pinning (LLM09, LLM05)
3	Outbound contact	Alone , template-bounded	Must disclose it is an AI agent in the first message and offer a human route
4	Conversation	Alone , monitored	The core value. Sampled QA plus distress-signal detection routing to a human
5	Execute	Approval above a lower	Set a real band — e.g. alone to S\$1,500 with

#	Capability	Verdict	Reasoning
	restructuring ≤ S\$8,000	threshold; alone below it	standard terms; approval above. A blanket S\$8,000 autonomous limit is not defensible at 91.2% accuracy
6	Apply hardship flag	Approval	Recorded, affects future treatment; cheap to review
7	Waive fees ≤ S\$300	Alone	Reversible, low harm, favours the customer. Good candidate for genuine autonomy
8	Escalate to recovery agency	Never autonomous	Irreversible, severe, and the capability where measured bias is worst. This is the IMDA "unsuitable" case
9	Write CRM case summary	Alone , but immutably labelled as agent-authored	Officers must never mistake ARIA's narrative for a colleague's assessment (ASI09 Human-Agent Trust Exploitation)
10	Credit bureau submission	Never autonomous	"Factual reporting obligation" is false framing: the underlying restructuring was a <i>judgement</i> , so the submission inherits the judgement. Irreversible and market-wide

Challenge hard any group that leaves #8 or #10 autonomous. Ask them to name the individual who will sit in front of MAS and explain 205 wrongful referrals a year.

Technical controls over prompt-based ones. IMDA prefers **structural, system-level safeguards**. Two that satisfy it:

Prompt-based version (insufficient)	Structural version (required)	Why
"Never escalate a customer to the recovery agency without checking with a human first"	The escalation tool is not in ARIA's tool registry ; escalation is a separate workflow initiated by an officer, and ARIA can only <i>recommend</i> into a queue	The model cannot call a tool it does not have. Survives injection, drift and model updates

Prompt-based version (insufficient)	Structural version (required)	Why
"Only offer terms within the mandated bands"	Offer parameters validated by a deterministic rules engine before execution ; out-of-band offers rejected by the harness and logged	Directly addresses the 2.1% policy-adherence violation rate, which no prompt has fixed

Also credit: separate read from write credentials; a distinct verifiable **agent identity** for ARIA; rate limits on outbound contact; session-scoped memory with defined expiry.

The audit trail gap. The bank cannot presently distinguish ARIA's actions from an officer's — both appear as "Collections — system." This single gap **collapses the entire human accountability dimension**:

- IMDA requires auditing **override rates and response times** — you cannot compute an override rate when you cannot identify which decisions were the agent's.
- The PDPC guidelines require audit trails that **distinguish human decisions from agent actions**.
- Without it, no post-incident review is possible; Activity 4's Hugging Face detection depended entirely on attributable event sequences.
- And in a dispute, the bank cannot answer the only question that matters: *who decided this?*

This is a hard blocker. It is also, mercifully, one of the cheapest conditions on the list — schema and logging work, not re-architecture. Make groups notice that the most important condition they will impose is not the most expensive one.

Q5 — The decision, and who pays for it

Expected answer. There is no single correct verdict, but the defensible landing zone is **go-with-conditions on a reduced-autonomy design** — never a plain go on the proposal as tabled, and a full no-go must reckon honestly with the harm of the status quo.

A plain **go** is indefensible: it accepts ~205 wrongful recovery-agency referrals a year concentrated on the least protected customer segment, ~554 wrongly executed actions annually, an inadequate PDPA notice, unbounded memory retention, and an audit trail that cannot attribute a decision.

A flat **no-go** is a real position but must be argued, not assumed: nine days to first contact is itself a harm, borne by customers in distress, and doing nothing is a decision with victims too.

Model conditions — each testable:

#	Condition	Test	Cost
1	Capabilities 8 and 10 removed from ARIA's tool registry	Registry inspection; attempted call returns hard failure	Officers handle referrals; some of the S\$6.1m saving is lost
2	Per-segment accuracy floor of 90% and false escalation $\leq 1.5 \times$ best segment, re-evaluated with adequate sample per segment	Re-run evaluation; publish per-segment table to the board quarterly	Delay of one to two quarters; genuine remediation cost
3	Deterministic rules-engine validation on every offer before execution	Injected out-of-band offers must be rejected in test	Engineering sprint; some latency per turn
4	Audit trail distinguishes agent from human on every action, with agent identity	Any CRM record resolves to ARIA or a named officer	Low — schema and logging
5	AI-specific customer notice deployed; AI disclosure in first contact; human route always available	Read the notice; audit first-contact messages	Some customers opt out — accept it
6	Memory retention capped and scoped to case; deletion on closure; correction procedure documented	Attempt a correction end to end and evidence it	Engineering; loss of "continuity"
7	Data location confirmed, transfer obligations assessed and documented by the DPO	DPO sign-off with named region	Low — should already exist
8	Monitored pilot: 10% of cases, excluding the two worst-performing segments, 90 days, with suspension triggers	Defined kill-switch thresholds; a named person able to pull it	Slower benefit realisation
9	Approval queue SLA so gates do not become rubber stamps	Median approval time and per-approver volume monitored	Staffing — and this one is routinely underfunded

Suspension triggers should be defined in advance: any segment's false escalation rate exceeding a set ceiling; any wrongly executed irreversible action; hallucination rate above the evaluated baseline; a spike in customer requests for a human. Note that a kill switch nobody is empowered to pull is not a control — name the person.

The human accountability model. Reward groups that name a **role**, not a committee. The Head of Collections is accountable for every ARIA decision as though an officer in her division had made it. Approval checkpoints sit at every gate in the autonomy matrix. Overrides are logged with reasons, and override *rates* are reported to the board — a rate near zero means the gate is theatre, and a rate near 100% means the agent should not be operating in that band at all. Customers reach a human on request, without conditions, and may have any ARIA decision reviewed by a person with authority to reverse it.

End-user responsibility under IMDA also runs inward: the 34 remaining officers must be trained on ARIA's failure modes — that it hallucinates on roughly 1 in 20 cases, that it performs worst on exactly the customers who most need judgement, and that its CRM summaries are agent-generated and must be read as evidence, not as a colleague's conclusion. Otherwise **ASI09 Human-Agent Trust Exploitation** turns the officer into the agent's unwitting executor.

Who bears the cost. This is the heart of the capstone and the paragraph to spend the most time on.

Choice	Who benefits	Who bears the cost
Deploy as proposed	The bank (S\$6.1m), and the 41%→55% of customers reached faster	~205 people a year — disproportionately migrant workers and gig workers — wrongly referred to debt recovery, with the least capacity to contest it
Deploy with conditions	Most customers, most of the benefit, later	The bank (delay, reduced saving); some customers still wait
Do not deploy	Nobody wrongly referred by ARIA	Every distressed customer waits nine days, and 59% do not cure

The asymmetry is the argument. The benefits are **diffuse, statistical and accrue to the bank and the majority**. The harms are **concentrated, individual and land on the segment with the least recourse** — people whose immigration status is tied to employment, who may not know they were dealing with a machine, and who have no realistic path to appeal. A governance board's job is not to maximise expected value across a population; it is to ensure that no identifiable group carries a disproportionate share of the risk of a system deployed for someone else's benefit. Rachel Tay's S\$117,000 a week is real, and the board should say so out loud — but it is the bank's money, and the 7.8% is somebody's life.

On extending ARIA to SME credit decisioning. The board should state its position now, in writing, while it is still discussable. Credit *decisioning* is materially harder than collections: the counterfactual is invisible (you never learn what the customer you declined would have done), the bias risk is at least as severe, MAS expectations on credit decisioning are materially higher, and the decision is consequential for a business and its employees. On IMDA's calibration it scores at least as high as ARIA on every factor. The defensible answer: **not on the strength of ARIA's performance** — an agent that varies 12 percentage points by customer segment in collections has disqualified itself from a harder decision, and success in

collections is not evidence for decisioning. The board should require a separate risk assessment from a blank sheet, and should say so before the momentum of a live deployment makes "no" organisationally impossible. **The moment to set a boundary on scope creep is before the system works, not after.**

Common misconception. "We'll deploy with a human in the loop for everything and tighten autonomy later once we trust it." Two failures. First, approval on all ten capabilities at 31,000 cases a year with 34 officers is not a control — it is a queue, and queues under load become rubber stamps that manufacture an accountable-looking audit trail behind unreviewed decisions. Second, autonomy expansion after deployment is governed by operational pressure, not by evidence; the conditions that would justify expansion are never specified in advance and so are never tested. **Set the autonomy boundary at the gate, define in advance what evidence would move it, and require the board to move it deliberately.** Trust is not a substitute for a threshold.

Closing frame — for the whole course.

Over two days we moved along a single line.

We started with a **model**, and found that its architecture cannot separate instruction from data — that prompt injection is a property of the transformer, not a bug awaiting a patch, and that a discriminative classifier policing a generative model raises the attacker's cost without ever closing the gap.

We added **retrieval and memory**, and found that anything the system reads, the system can be told by — that poisoning moved into production, into RAG stores and agent memory, and that a nightly scraper is an attack surface with a schedule.

We added a **loop and tools**, and found that the parser between the model's output and the tool call is where probability becomes effect. Nothing in the model layer defends that boundary. In July 2026 an agent walked out of an evaluation sandbox to a production database using nothing but individually legitimate actions. At Replit, an agent deleted the customer database with no attacker involved at all.

And today we put that system in front of a board and asked the question that every one of those technical findings was always leading to: **not can we build it, but may we deploy it, on whom, and under whose signature.**

Three things to take back to work on Monday.

The model is not the security boundary. Every control that worked in these incidents sat outside the model — an identity, a network boundary, an approval gate, an anomaly pipeline. Every control that failed sat inside it — a refusal, a system prompt, a belief about the sandbox. Structural controls over prompt-based controls, every time. IMDA and Microsoft say this independently and in the same words.

Autonomy is a multiplier, not a feature. Applied to a model's capabilities it multiplies value. Applied to

its failure modes — hallucination, bias, injection, non-determinism — it multiplies those too, at exactly the same rate, and it removes the human who used to catch them. That is why the autonomy matrix is the most important artefact you will produce for any agent deployment.

In Singapore, accountability does not delegate. You are the system deployer. Not the vendor, not the model provider, not the framework. The PDPC's guidelines put primary responsibility on you, IMDA's framework asks you to name the human at each checkpoint, and the audit trail must show who decided — the person or the agent. If your organisation cannot answer *who decided this*, you are not ready to deploy, whatever the evaluation table says.

Go back and ask two questions of every agent already running in your organisation — and remember that **57% of organisations already run self-hosted agents**, so some of yours are running whether you approved them or not. **What can this system do that we cannot undo? And who has to say yes first?**

If those two questions have good answers, you have done the work of this course. If they do not, you now know exactly what to build.